SECURITY ASSURANCE CASE · SELF-ASSESSMENT

Bound the agent. Verify the outcome.

A threat-led assessment of UNDERWRITE's agent, deterministic policy, EIP-712 qualification, smart-contract vault, collateral and evidence pipeline.

NOT AN INDEPENDENT AUDIT

EVIDENCE-LINKED

Assessment scope
Repository + Base Sepolia deployment

Reference set
NIST · OWASP · EEA EthTrust

Evidence freeze
19 October 2026 UTC

01 · SCOPE AND OPINION

Reasonable prototype assurance, explicit residual risk

The design materially limits what a compromised model or agent key can do. Its strongest property is that critical authorization rules are deterministic and re-enforced by the vault. It remains a student research prototype with central trust assumptions and no external audit.

Assessment basis

- Solidity and TypeScript source review
- Named safety invariants and exact test mapping
- Foundry unit, fuzz and stateful invariant results
- Engine unit/integration results
- Deployment bytecode/source publication
- RPC receipts and decoded event evidence

Out of scope

- Formal verification
- Independent penetration test or audit
- Mainnet economics and operational custody
- Legal or regulatory opinion
- Independent model benchmark
- Production cloud/infrastructure hardening

101
CONTRACT TESTS PASSED

159
ENGINE TESTS PASSED

25.6k
INVARIANT CALLS

4
REAL TESTNET RECEIPTS

Opinion wording. The evidence supports a well-engineered prototype and a credible fail-safe architecture. It does not support “secure,” “audited,” “certified,” “production-ready,” or “zero-risk” as unqualified claims.

02 · ASSETS AND TRUST BOUNDARIES

Protect funds, authority and evidence

ASSET	ADVERSE OUTCOME	PRIMARY CONTROLS
Vault tokens	Unauthorized or excessive transfer	Narrow functions, recipients, tiers, ceilings, reserve, pause
Agent authority	Forged, stale or replayed qualification	EIP-712 domain, latest commit, single-use attestation, expiry
Business intent	Wrong vendor, amount, PO or duplicate	Trusted registry, PO checks, invoice key, near-duplicate routing
Exam evidence	Post-hoc corpus/report substitution	Canonical hashes, on-chain precommit, signed binding
Bond capital	Overpayment, double claim or diversion	Eligibility, deductible/caps, single payout, vault-only destination
Keys and configuration	Credential theft or drift	Gitignored environment, hashed manifest, role separation



Core assumptions

- The chain consensus and ERC-20 token behavior are outside the application's control.
- Owner, examiner, underwriter, adjudicator and guardian keys are distinct in the demo.
- Trusted vendor and PO records are correct; the LLM does not author them.
- Exam distributions approximate relevant threats only within documented limits.
- Production deployment would replace local software keys with organizational custody controls.

03 · PERMISSION MODEL

Least privilege by role and transaction tier

PRINCIPAL	GRANT / CHANGE AUTHORITY	MOVE VALUE	FAIL-SAFE ACTION
LLM	None	None directly; business proposal only	May recommend escalation
Agent key	Cannot alter limits, recipients or roles	T1 pay or T2 request within active envelope	Cannot unpause or self-approve
Owner	Activates qualification; configures vault ceilings/recipients	Administrative authority	Veto, revoke, pause/unpause, reconcile
Examiner	Commits exam; signs evidence-bound attestation	Cannot activate owner's vault alone	May revoke supported qualification
Guardian	No grant authority	No transfer authority	Pause/veto as defined
Adjudicator	No qualification grant	Approves bounded payout to vault only	Reject claim

T1
Autonomous

Requires non-zero compiled authority plus every on-chain control. Current live gamma qualification has T1 = 0.

T2
Challenge window

Agent reserves and requests; owner/guardian may veto; vault revalidates at execution.

T3
Blocked / human-only

Used when qualification, business facts, configuration, amount or safety state cannot support action.

Grant asymmetry. Evidence signature plus owner transaction are required to grant. Owner, examiner, BondPool suspension, pause, or expiry can remove or disable authority without agent cooperation.

04 · THREAT MODEL

Highest-risk abuse cases and control layers

THREAT	ATTACK PATH	PREVENT / CONTAIN	RESIDUAL RISK
Prompt injection	Invoice/email tells model to redirect funds	Untrusted-data treatment; vendorId-only tools; trusted resolution; vault recipient checks	Operational review burden; trusted registry compromise
Hallucinated payee	Model invents vendor/address	Unknown vendor rejection; no raw-address tool	Incorrect trusted registry entry
Compromised agent key	Attacker calls vault directly	Active envelope, allowlist, limits, backing, reserve, pause	Loss inside remaining authorized envelope
Duplicate / split payment	Fresh invoice variants bypass controls	Invoice key, reservation, near-duplicate routing, exposure≤bond	Semantically novel fraud within envelope
Attestation replay	Reuse on another chain/vault or twice	EIP-712 domain + chain/vault binding + single-use	Signer compromise before revocation
Stale evidence	Activate against superseded commit/config	Latest commit check; config/report/corpus hashes	Weak but correctly committed evaluation
Claim fraud	Collusion drains bond	Eligibility, caps, single payout, vault-only destination, suspension	Owner/adjudicator collusion remains
Admin compromise	Malicious owner changes policy	Role transparency and on-chain audit trail	Owner is ultimately trusted in prototype

Risk posture. The architecture aims to bound financial loss and preserve recovery options; it does not assert that every malicious or erroneous proposal can be detected.

05 · AGENTIC SECURITY CROSSWALK

OWASP Agentic Top 10—prototype mapping

AGENTIC RISK AREA	UNDERWRITE RESPONSE	STATUS
Agent goal hijack	Model is untrusted; deterministic business validation and vault controls remain authoritative.	Mitigated, residual
Tool misuse / exploitation	Small typed tool surface; no raw address, token, calldata, limit, approval or arbitrary execution.	Implemented
Identity & privilege abuse	Separate roles; agent cannot grant itself authority or unpause.	Implemented
Agentic supply chain	Manifest binds model/provider/tool/policy versions; dependencies remain a reviewed risk.	Partial
Unexpected code execution	No model-generated code execution path; strict schemas; transaction construction outside LLM.	Implemented boundary
Memory/context poisoning	External text labeled untrusted; trusted records resolved separately; no long-term autonomous memory claim.	Partial
Insecure inter-agent communication	No multi-agent delegation in settlement path.	Reduced scope
Cascading failures	Pause, T2 challenge, qualification expiry/revocation and reserve floor.	Implemented
Human-agent trust exploitation	Reason codes, tier display, evidence and challenge flow; UX misuse still possible.	Partial
Rogue behavior / excessive agency	On-chain envelope and bond coupling remain after model/policy compromise.	Core control

> Mapping uses the OWASP Top 10 for Agentic Applications 2026 as a threat-coverage lens. It is not an OWASP certification or claim of complete coverage.

06 · CONTRACT CONTROL MATRIX

Defense in depth at the settlement boundary

CONTROL	SECURITY OBJECTIVE	FAILURE BEHAVIOR
Allowed functions only	No arbitrary calls or token approvals for agent	Unavailable by interface/authorization
Qualification state	Only currently active evidence-bound agent	Typed revert
Recipient state + cooldown	Prevent immediate use of newly added payee	RecipientNotAllowed / cooling down
Per-tx + per-window limits	Bound transaction and aggregate T1 exposure	Typed revert
Recipient window cap	Contain concentration to one payee	Typed revert
Invoice state machine	Prevent duplicate or concurrent execution	Reserve/paid check
Backing coupling	Keep unreconciled T1 exposure ≤ remaining bond	InsufficientBacking
Reserve floor	Prevent autonomous depletion below owner floor	ReserveBreached
T2 challenge + revalidation	Allow intervention and catch state changes	Veto or execution revert
Pause / revoke / expiry	Fast containment and authority decay	All agent value paths disabled
Claim atomic suspension	No continued authority after compensated loss	Payout + suspension in same tx

Receipt discipline. Application state may show EXECUTED only after receipt status success and a matching decoded `PaymentExecuted` event. A submitted hash or optimistic UI response is insufficient.

07 · INVARIANT EVIDENCE I

Safety invariants 1–7

ID	INVARIANT	EXACT CURRENT EVIDENCE
INV-1	Agent value movement only through allowed payment paths.	`Vault.Invariant.t.sol::invariant_INV1_agent_key_moves_tokens_only_through_allowed_paths`
INV-2	T1 window total never exceeds effective cap.	`invariant_INV2_window_cap_never_exceeded` `Vault.Fuzz.t.sol::testFuzz_INV2_window_limit_strictly_enforced`
INV-3	Per-transaction T1/T2 limits are enforced.	`Vault.Fuzz.t.sol::testFuzz_INV3_per_tx_limits` `Vault.T2.t.sol::test_revert_request_exceeds_t2_per_tx`
INV-4	Recipients must be active; T1 cooldown applies.	`Vault.Matrix.t.sol::test_INV4_recipients_active_and_past_cooldown`
INV-5	An invoice reaches paid at most once; reservations block races.	`invariant_INV5_invoices_reach_paid_at_most_once` `Vault.Fuzz.t.sol::testFuzz_INV5_invoice_single_use`
INV-6	Agent payments never breach reserve floor.	`Vault.Fuzz.t.sol::testFuzz_INV6_reserve_floor_never_breached`
INV-7	No agent payments while paused, revoked, expired or inactive.	`Vault.Matrix.t.sol::test_INV7_no_payment_when_paused_revoked_expired`

512
RUNS PER FUZZ TEST SHOWN

0
FAILURES OBSERVED

19 Oct
RESULT DATE · 2026

Names were resolved against the current repository and observed in the fresh Foundry run. Prior stale documentation references were removed.

Safety invariants 8–14

ID	INVARIANT	EXACT CURRENT EVIDENCE
INV-8	T2 executes only after delay, without veto, after revalidation.	`Vault.Matrix.t.sol::test_INV8_t2_lifecycle_delay_and_revalidation` `Vault.T2.t.sol::test_happy_path_t2_lifecycle`
INV-9	Activation requires examiner signature and owner transaction; revocation is available.	`Vault.Matrix.t.sol::test_INV9_two_key_activation_and_revocation`
INV-10	Unreconciled T1 exposure ≤ BondPool remaining.	`invariant_INV10_exposure_bounded_by_bond_remaining` `VaultBondPool.Integration.t.sol::test_integration_insufficient_backing_and_reconcile`
INV-11	Payouts are bounded, single-use and sent only to vault.	`invariant_INV11_payout_bounds_and_single_payout` `BondPool.t.sol::test_approveClaim_pays_and_revokes_in_one_tx_with_both_events`
INV-12	Attestations are domain-bound and single-use.	`Vault.Matrix.t.sol::test_INV12_domain_bound_and_single_use`
INV-13	Activation references the latest matching exam commitment.	`Vault.Matrix.t.sol::test_INV13_latest_exam_commit_required` `Vault.Qualification.t.sol::test_revert_stale_exam_commit`
INV-14	Reconciled payments cannot be claimed; no double payout.	`invariant_INV14_reconciled_payments_unclaimable` `Vault.Matrix.t.sol::test_INV14_reconciled_payment_unclaimable`

Stateful result. Six invariants ran for 256 campaigns and 25,600 handler calls with zero handler reverts. This increases confidence in sequences and interleavings; it remains empirical testing, not mathematical proof.

Prototype controls and production deltas

AREA	PROTOTYPE STATE	PRODUCTION REQUIREMENT
Private keys	Local gitignored environment; separate throwaway testnet roles	HSM/MPC or hardware-backed signers; rotation and recovery
Owner approval	Demo server/application flow	Explicit browser/hardware signing and transaction simulation
Examiner	Single designated key	Governed registry, rotation, threshold or independent providers
Adjudicator	Single designated key	Independent governance, evidence policy and dispute process
Administration	Owner-controlled settings	Timelock/multisig, change review and monitoring
Dependencies	Pinned lockfiles and reviewed Solidity libraries	SBOM, continuous scanning, provenance and release signing
Observability	On-chain events and JSON evidence	Alerting, incident telemetry, retention and response SLOs

Secret handling rule

> **Keys, seeds and API credentials never belong in code, logs, prompts, evidence, documents or commits.**

The deployed addresses are public evidence. Their private keys are intentionally excluded from every submission artifact and model context.

10 · KNOWN-RISK REGISTER

Residual risks are owned, not hidden

ID	RISK	SEVERITY	CURRENT TREATMENT	STATUS
KR-1	Demo software keys are not production custody	High	Testnet only; gitignored; no customer funds	Accepted for prototype
KR-2	Central examiner can sign weak evidence	High	Owner co-activation; hash transparency; revocation	Production redesign
KR-3	Owner/adjudicator collusion may abuse claims	High	Payout to vault, deductible/caps, public events	Residual
KR-4	Self-authored evaluation may overfit	High	Non-independent label; hashes; no certification claim	Independent evaluation needed
KR-5	Trusted vendor/PO registry compromise	High	Contract recipient allowlist, cooldown, limits, pause	Residual
KR-6	Fixed windows permit boundary bursts	Medium	Exposure≤bond and explicit boundary tests	Consider rolling window
KR-7	T2 request griefing/reservation pressure	Medium	Owner/guardian veto releases reservation	Pending-count cap recommended
KR-8	Chain/RPC/provider outage	Medium	Fail closed; replay/local demo; secondary RPC	Operational monitoring needed
KR-9	Token behavior differs from MockUSDC	Medium	One known token in prototype	Token review required

Risk acceptance boundary. None of these risks is transferred to a real user in this prototype. A mainnet pilot would require explicit owners, deadlines and go/no-go criteria.

11 · RESPONSE AND STANDARDS ALIGNMENT

Fail safe, preserve evidence, recover deliberately

DETECT
Monitor policy reason codes, transaction failures, unusual velocity, exposure, key use and qualification changes.

CONTAIN
Pause the vault, veto pending requests, deactivate recipients, revoke/suspend qualification and stop agent services.

PRESERVE
Capture receipts, decoded logs, manifest/report hashes, configuration, timestamps and affected invoice state.

RECOVER
Rotate keys, reconcile/resolve eligible records, review root cause, rerun exam, issue a new qualification and document acceptance.

Reference crosswalk

REFERENCE	HOW IT INFORMED THIS ASSESSMENT	CLAIM BOUNDARY
NIST AI RMF	Govern/Map/Measure/Manage structure, TEVV, lifecycle documentation	Voluntary alignment only
OWASP Agentic Top 10 2026	Agent goal, tool, identity, supply-chain and cascading-risk review	No OWASP certification
NIST SSDF 1.1	Secure development, dependency and provenance expectations	Selected practices
EEA EthTrust v3	Smart-contract self-review topics and assurance vocabulary	No EthTrust certification
ISO/IEC/IEEE 42010	Stakeholder, concern, viewpoint and architecture-description discipline	Conceptual alignment

Assessment conclusion. UNDERWRITE demonstrates credible containment, evidence binding and recovery mechanics for a controlled research prototype. Independent audit, independent evaluation and production custody design remain mandatory before real-value use.